

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)*

Assessment Tool Weightage: 35%

QUESTIONS: 5

Total Marks:100

K Nitheesh Kumar / 192325090K Nitheesh Kumar / 192325090_____

1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.
2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.
3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can

be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.
5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

Code of Conduct:

I K Nitheesh Kumar / 192325090 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K Nitheesh Kumar

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided
Clarity	10	Clear, well-structured, and easy to understand	Organized and understandable presentation	Limited clarity and structure	Poor clarity difficult to understand

CO4 – ASSESSMENT TOOL 3

CASE STUDY – DETAILED ANSWERS

Student Name: K Nitheesh Kumar | Register No.: 192325090

Course: Ethical Hacking | Course Code: ITA14

The case-study questions in the supplied document cover web-server assessment, web-application vulnerabilities, wireless Evil Twin attacks, combined wireless/web penetration testing, and wireless deauthentication attacks. 穀filecite學turn2file0學L11-L42像 穀filecite學turn2file0學L44-L62像

Ethical scope: All assessment and testing steps below are intended only for an authorized, isolated laboratory environment. Commands are presented as controlled examples using placeholders; they should not be directed at public or third-party systems.

QUESTION 1 – E-COMMERCE WEB SERVER SECURITY ASSESSMENT

1.1 Case Understanding

The case describes a mid-sized e-commerce company operating an Apache web application on Linux. Customers reported unauthorized transactions and abnormal account activity. Investigation identified suspicious HTTP requests, including attempts to access hidden directories and injection of malicious scripts into input fields. The server was also running an outdated version with known vulnerabilities and had no Web Application Firewall (WAF). 穀filecite學turn2file0學L11-L16像

1.2 Possible Attack Vectors

Attack Vector	How It Could Be Used	Potential Effect
Outdated Apache/software	An attacker may target a known vulnerability in an exposed component.	Server compromise or unauthorized access.
Hidden-directory discovery	Requests may enumerate administrative, backup or configuration resources.	Information disclosure or access to sensitive functionality.
Malicious script injection	Poor input validation may allow attacker-controlled content into application responses.	XSS, session abuse or fraudulent user actions.
Weak application controls	Insufficient authentication/authorization can expose accounts or transactions.	Account takeover or unauthorized transactions.
No WAF	Malicious HTTP patterns may reach the application without an additional filtering layer.	Higher exposure to common web attacks.

1.3 Reconnaissance Methodology

Reconnaissance should begin with passive and low-impact identification of the approved target, followed by service discovery and web-technology fingerprinting. The analyst should record the target's IP address, domain, exposed services, web-server version, application technologies and observable attack surface.

```
ip addr  
  
ping -c 4 <authorized-target>  
  
nmap -sV <authorized-target>  
  
whatweb http://<authorized-target>  
  
curl -I http://<authorized-target>
```

1.4 Vulnerability Scanning

After reconnaissance, controlled vulnerability scanning can identify outdated services, exposed files and common web weaknesses. Nikto can help identify web-server misconfigurations and risky resources. An intercepting proxy such as Burp Suite or OWASP ZAP can be used to inspect application requests and responses.

```
nikto -h http://<authorized-target>
```

```
gobuster dir -u http://<authorized-target> -w <approved-wordlist>
```

1.5 Controlled Validation and Exploitation

The assessment should validate suspected vulnerabilities only within the approved laboratory. Exploitation should be limited to safe proof-of-concept behavior that demonstrates the weakness without modifying real customer data, damaging services or creating persistence. For example, a suspected outdated-service vulnerability should first be confirmed by version and configuration evidence; a suspected input-validation issue should be tested with benign laboratory input and observed through the application's response.

1.6 Layered Defense Strategy

- Patch and upgrade Apache, operating-system packages and application dependencies.
- Remove unused modules, services, backup files and development artifacts.
- Implement strong authentication and server-side authorization for transactions and account functions.
- Validate input using allowlists where appropriate and encode output according to its context.
- Deploy a WAF as an additional protective layer, while recognizing that secure application code remains essential.
- Use network segmentation so the public web tier cannot directly access unrelated internal systems.
- Protect databases using least privilege and restrict database connectivity to required application hosts.
- Centralize logs for authentication, transaction and suspicious HTTP activity.
- Use MFA for administrative and high-risk user actions.
- Perform recurring vulnerability assessment and patch verification.

1.7 Risk Summary

Finding	Severity	Impact	Priority
Outdated vulnerable server	High/Critical if exploitable	Potential server compromise	Immediate
Script injection/input validation weakness	High	Account/session abuse and malicious actions	Immediate
No WAF	Medium–High	Reduced defense against common web attacks	High
Hidden sensitive resources	Medium–High	Information disclosure or unauthorized access	High
Weak transaction protection	Critical	Unauthorized financial transactions	Immediate

QUESTION 2 – SQL INJECTION AND XSS SECURITY AUDIT

2.1 Case Understanding

The financial application permits login, account viewing and transactions. The case states that SQL injection and Cross-Site Scripting (XSS) vulnerabilities were identified, error messages exposed database-structure

information, and user inputs were not properly sanitized. Attackers used these weaknesses to extract customer data and inject malicious scripts into pages viewed by other users. 穀filecite學turn2file0學L23-L33像

2.2 SQL Injection Analysis

SQL injection occurs when application-controlled input is incorporated into a database query without safe parameterization. In this case, exposed database information in error messages can provide additional information about the underlying data model. A secure audit should determine whether parameters are handled using prepared statements and whether database errors are safely handled.

2.3 XSS Analysis

XSS occurs when untrusted input is returned to a user's browser in a context where it can be interpreted as executable script. In the case, malicious content was injected into pages viewed by other users. A successful stored or reflected XSS issue could affect account confidentiality, session security and transaction integrity.

2.4 Burp Suite Methodology

- Configure Burp Suite as the browser's authorized interception proxy.
- Browse the approved application using a test account.
- Capture login, account and transaction requests.
- Identify parameters that accept user-controlled values.
- Replay requests safely in Repeater using controlled test input.
- Compare normal and test responses and document evidence.
- Redact credentials, tokens and personal information from screenshots.

2.5 SQLmap Validation

SQLmap can be used in a controlled laboratory to validate a suspected SQL injection parameter. The analyst should first obtain a sanitized request from Burp Suite and use the narrowest safe testing scope. The goal is confirmation, not extraction of real customer information.

```
sqlmap -r <sanitized-request-file> --batch --level=1 --risk=1
```

If the tool reports a possible injection point, manually validate the behavior and confirm whether the application actually permits unintended query manipulation. Do not dump real customer databases in an academic assessment.

2.6 CIA Impact

CIA Element	SQL Injection Impact	XSS Impact
Confidentiality	Customer/account/database information may be exposed.	Session or sensitive page information may be exposed through malicious script execution.
Integrity	Unauthorized database changes may be possible if the vulnerable operation permits them.	Attacker-controlled script can alter displayed content or initiate actions in a victim's browser.
Availability	Abusive queries or database manipulation may affect service availability.	Usually lower direct availability impact, but malicious scripts can disrupt application use.

2.7 Mitigation

- Use parameterized queries/prepared statements for database access.
- Apply server-side input validation and avoid constructing SQL from raw input.
- Return generic database errors rather than schema details.

- Contextually encode untrusted output before rendering it.
- Use an appropriate Content Security Policy as defense in depth.
- Protect sessions with Secure, HttpOnly and suitable SameSite cookie settings.
- Use MFA and strong authentication for sensitive financial functions.
- Log suspicious requests and monitor transaction anomalies.
- Retest after remediation.

QUESTION 3 – WIRELESS EVIL TWIN ATTACK

3.1 Case Understanding

The corporate office uses WPA2-PSK wireless authentication. Employees reported unusual login prompts and slow performance. Investigation found a rogue access point using an Evil Twin configuration that mimicked the official SSID. Attackers used the setup to capture credentials and conduct man-in-the-middle attacks.

3.2 How the Evil Twin Attack Works

An Evil Twin creates a fraudulent wireless network that resembles a legitimate network. Users may connect because the SSID looks familiar, because their device automatically reconnects, or because the attacker creates a convincing login/captive-portal experience. Once a victim connects, traffic may pass through infrastructure controlled by the attacker. The central weakness is that SSID names alone do not establish trust.

3.3 Weaknesses in WPA2-PSK Deployment

- A shared pre-shared key provides weaker individual accountability than enterprise authentication.
- Users may accept a network based only on its SSID.
- Automatic connection can increase the likelihood of joining a fraudulent network.
- A captive portal or login prompt can be imitated.
- Without strong certificate validation, users may be tricked into entering credentials into a fraudulent service.
- Insufficient wireless monitoring can delay rogue-AP detection.

3.4 Aircrack-ng and Wireshark

In an authorized lab, Aircrack-ng tools can help inventory wireless networks and analyze the security configuration. Wireshark can capture and inspect permitted network traffic and management activity to understand the presence and behavior of suspicious infrastructure. These tools should be used only against the laboratory environment and approved channels.

```
airmon-ng
airodump-ng <authorized-monitor-interface>
wireshark
```

3.5 Detection Indicators

Indicator	Meaning
Duplicate SSID with different BSSID	Possible rogue/Evil Twin access point.
Unexpected signal strength/location	Possible nearby unauthorized transmitter.
Repeated login/captive-portal prompts	Potential credential-harvesting attempt.
Certificate warnings	Possible interception or fraudulent service.
Unexpected DNS/network path	Traffic may be redirected through unauthorized infrastructure.
Abnormal latency/disconnections	Possible interference or malicious wireless activity.

3.6 Countermeasures

- Migrate toward WPA2-Enterprise or WPA3-Enterprise where supported.
- Use 802.1X and certificate-based authentication for managed enterprise devices.
- Deploy wireless intrusion detection/prevention to identify rogue APs.
- Use network access control to restrict unmanaged devices.
- Reduce unnecessary automatic Wi-Fi connection behavior on managed endpoints.
- Educate users never to enter corporate credentials into unexpected wireless portals.
- Use secure DNS and HTTPS throughout enterprise applications.
- Monitor authentication logs and correlate wireless events with endpoint alerts.

QUESTION 4 – COMBINED WIRELESS AND WEB APPLICATION PENETRATION TEST

4.1 Case Understanding

The organization hosts a web-based employee-management system accessible over Wi-Fi. The wireless network uses weak passwords, while the application has weak authentication and session management. An attacker gains wireless access, performs reconnaissance, exploits the web application, escalates privileges and accesses confidential employee data. 穀filecite學turn2file0學L44-L53傢

4.2 Attack Chain

Phase	Activity	Security Failure
1. Wireless compromise	Attacker obtains unauthorized Wi-Fi access.	Weak wireless password/security.
2. Reconnaissance	Identify hosts, ports and web services.	Insufficient network isolation.
3. Scanning	Identify application and service weaknesses.	Outdated or misconfigured components.
4. Web exploitation	Target authentication/session weaknesses.	Weak application controls.
5. Privilege escalation	Attempt access beyond normal user permissions.	Missing server-side authorization.
6. Data access	Reach confidential employee information.	Insufficient access control and segmentation.

4.3 Reconnaissance and Scanning

```
ip addr
nmap -sV <authorized-lab-network-target>
whatweb http://<authorized-target>
curl -I http://<authorized-target>
```

The analyst should map only the approved internal laboratory range. Results should be correlated with the intended architecture so that unexpected exposed services can be identified.

4.4 Web Application Testing

Use Burp Suite or OWASP ZAP to capture authentication, session and employee-record requests. Examine session identifiers, logout behavior, authorization decisions and access to protected endpoints. Test with faculty-provided accounts and test records rather than real employee information.

4.5 Privilege-Escalation Assessment

Privilege escalation should focus on whether the server verifies the user's role for every sensitive operation. A normal employee account should not be able to access administrator functions merely by changing a client-side parameter or navigating directly to an administrative endpoint.

4.6 Defense-in-Depth Framework

- Use WPA2-Enterprise/WPA3-Enterprise with strong identity management.
- Segment employee Wi-Fi from sensitive server and management networks.
- Use firewalls and deny-by-default rules between network zones.
- Require MFA for privileged web functions.
- Rotate and invalidate sessions securely.
- Perform server-side authorization on every sensitive endpoint.
- Use secure cookies and HTTPS.
- Apply endpoint protection and NAC.
- Centralize logs across Wi-Fi, firewall and web application layers.
- Conduct periodic penetration tests and remediation verification.

QUESTION 5 – WIRELESS DEAUTHENTICATION ATTACK

5.1 Case Understanding

The university campus experiences repeated Wi-Fi disruptions during peak hours. Investigation attributes the interruptions to repeated deauthentication attacks against access points, causing legitimate clients to disconnect. The attacker continuously sends deauthentication packets, creating a denial-of-service condition.

5.2 Technical Explanation

IEEE 802.11 uses management frames to maintain wireless connectivity. Historically, some management frames were not cryptographically protected, allowing an attacker within radio range to transmit forged deauthentication frames. A client receiving a valid-looking frame may disconnect from its access point and attempt to reconnect. Repetition can significantly reduce network availability.

5.3 Controlled Analysis with Kali Linux

For an academic laboratory, the safest approach is to capture and analyze management traffic rather than continuously disrupt a real network. Aircrack-ng tools can assist with authorized wireless monitoring, while Wireshark can filter and inspect management frames.

```
airmon-ng  
  
airodump-ng <authorized-monitor-interface>  
  
wireshark
```

In a controlled lab, faculty-approved simulation can be used to demonstrate the effect of management-frame abuse. No deauthentication traffic should be transmitted against campus, public or third-party networks.

5.4 Detection

Detection Signal	Interpretation	Response
High rate of deauthentication frames	Possible deliberate disruption.	Correlate source BSSID/client and investigate.

Many clients disconnect simultaneously	Possible wireless availability attack.	Check AP/controller and RF telemetry.
Unknown transmitter near AP	Possible rogue device.	Locate and isolate through approved procedures.
Repeated reconnect cycles	Potential management-frame abuse or interference.	Check wireless logs and client behavior.

5.5 Availability and Productivity Impact

The primary impact is availability. Repeated disconnections interrupt online classes, authentication, cloud applications, file transfers and communications. During peak periods, the same attack can affect a large number of users simultaneously, causing loss of productivity and increased support workload.

5.6 Mitigation

- Enable Protected Management Frames (PMF/802.11w) where supported.
- Use modern WPA2/WPA3 configurations appropriate to campus equipment.
- Deploy wireless intrusion detection/prevention systems.
- Monitor deauthentication and disassociation event rates.
- Use controller-side analytics to identify abnormal client churn.
- Maintain RF monitoring to distinguish deliberate management-frame abuse from ordinary interference.
- Segment critical services and provide resilient connectivity for essential systems.
- Document incident-response procedures for wireless denial-of-service events.
- Coordinate technical response with institutional security and legal/policy teams.

COMPARATIVE RISK ANALYSIS

Question	Primary Threat	Confidentiality	Integrity	Availability	Overall
1	Web-server and input vulnerabilities	High	Critical	High	Critical
2	SQL Injection and XSS	Critical	High	Medium	Critical
3	Evil Twin / MITM	High	High	High	Critical
4	Wireless-to-web attack chain	Critical	Critical	High	Critical
5	Deauthentication DoS	Low–Medium	Low	Critical	High

OVERALL SECURITY FRAMEWORK

1. Prevent

Preventive controls reduce the probability that an attacker can obtain an initial foothold. Strong wireless authentication, modern encryption, secure application coding, patch management, network segmentation and least privilege are foundational controls.

2. Detect

Detection requires visibility across wireless, network and application layers. Wireless IDS/IPS, centralized logs, authentication monitoring, endpoint alerts and web-application telemetry should be correlated to identify abnormal activity.

3. Respond

When an incident is detected, the organization should isolate affected systems, disable compromised accounts, preserve logs and determine the scope of exposure. Wireless incidents may require physical investigation for rogue devices.

4. Recover

Recovery includes restoring services, rotating credentials, applying patches and configuration changes, validating that vulnerabilities are fixed and communicating appropriately with affected stakeholders.

5. Improve

Lessons learned should feed back into security architecture, training, policies and future testing. Regular vulnerability assessments and controlled penetration tests should verify that corrective measures remain effective.

FINAL CONCLUSION

The five cases demonstrate that web and wireless security must be treated as interconnected layers. The e-commerce case combines outdated software, input-validation weaknesses and missing protective layers. The financial case shows how SQL injection and XSS can affect confidentiality and integrity. The Evil Twin case demonstrates that a trusted-looking SSID is not a trustworthy identity mechanism. The combined Wi-Fi/web case shows how an initial network compromise can become a pathway to sensitive application data. Finally, the deauthentication case illustrates that wireless management-frame weaknesses can directly affect availability. Strong authentication, modern encryption, segmentation, secure coding, monitoring, protected management frames, user awareness and disciplined incident response together provide a practical defense-in-depth strategy.

REFERENCES TO THE SUPPLIED CASE-STUDY DOCUMENT

The report is based on the five questions and case descriptions in the uploaded Assessment Tool 3 – Case Study. The supplied document states that the assessment covers CO4 and requires application of ethical-hacking concepts to the five scenarios. 穀filecite學turn2file0學L2-L9像

Question 1 and Question 2 focus respectively on the e-commerce web-server incident and financial web-application vulnerabilities. 穀filecite學turn2file0學L11-L33像

Question 3 covers the corporate Evil Twin wireless incident, while Questions 4 and 5 cover the combined wireless/web attack chain and university Wi-Fi deauthentication attacks. 穀filecite學turn2file0學L34-L62像